

I added the domain to my etc/hosts file

```
# Your system has con
# As a result, if you
# then you will need
# a.) make changes to
# b.) change or remov
# /etc/cloud/clou
#
127.0.1.1 htb-ggykhzr
127.0.0.1 localhost

# The following lines
::1 localhost ip6-loc
ff02::1 ip6-allnodes
ff02::2 ip6-allrouter

127.0.0.1 localhost
127.0.1.1 htb-ggykhzr
10.10.11.11 board.htb
```

I tried to investigate the webpage but found very little information To explore this issue further, we attempted subdomain enumeration in hopes of uncovering any subdomains that might reveal potential vulnerabilities.

For the subdomain enumeration, I utilized ffuf. Initially, the default ffuf enumeration returned various status codes and sizes. To refine the results, I filtered the output to display only the subdomains with a status of 200 OK. Additionally, since all responses had a size of 15,949 bytes, I adjusted the parameters to exclude packets of this size.

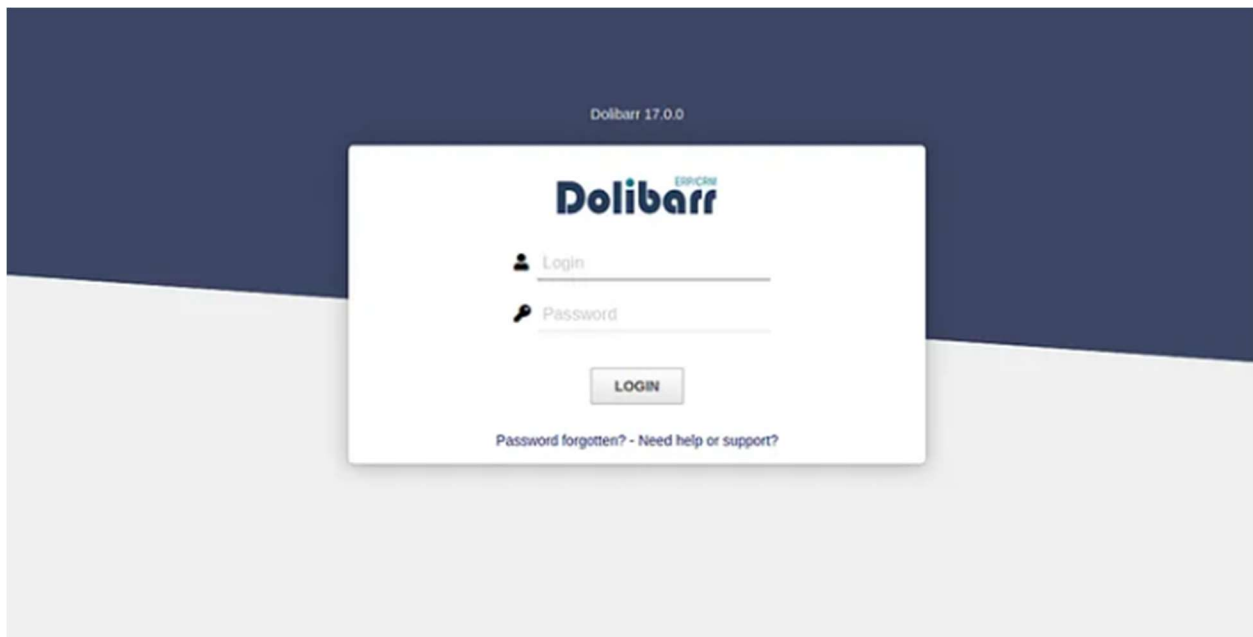
This helped me to find the crm subdomain, which I added to my hosts file.

```

# Your system has configured 'manage_etc'
# As a result, if you wish for changes to
# then you will need to either$
# a.) make changes to the master file in
# b.) change or remove the value of 'man
# /etc/cloud/cloud.cfg or cloud-confi
#$
127.0.1.1 htb-ggykhzrftq.htb-cloud.com
127.0.0.1 localhost$
$
# The following lines are desirable for
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes$
ff02::2 ip6-allrouters$
$
127.0.0.1 localhost$
127.0.1.1 htb-ggykhzrftq htb-ggykhzrftq
10.10.11.11 board.htb crm.board.htb$

```

Upon visiting the site I found it is a dolibarr page



First, we need to investigate whether Dolibarr version 17.0.0 is vulnerable. Our research indicates that version 17.0.0 is no longer secure and has known exploits documented on various websites. The vulnerability is identified by CVE-2023-30253. With the correct parameters I got a reverse shell with access to the data.

Was then able to try reading the password file

```
$ cat /etc/passwd | grep -i sh$
root:x:0:0:root:/root:/bin/bash
larissa:x:1000:1000:larissa,,,:/home/larissa:/bin/bash
$ █
```

It looks like there is a user called larissa, I will be using this account to try and login

I then searched for conf files to try and find information on the larissa account.

I found a php file with credentials

```
$dolibarr_main_db_user='dolibarowner';
$dolibarr_main_db_pass='serverfun2$2023!!';
```

After using ssh to log into the larissa account I was able to cat the user.txt file and find the user flag!

To get some valuable information about weaknesses and interesting files about the system, linpeas could be very useful. Linpeas is a script used for privilege escalation on Unix-based systems, typically during security assessments or penetration testing. It is part of the PEAS (Privilege Escalation Awesome Scripts) suite, which is designed to identify potential privilege escalation vectors.

I used inpeas on the system and found Some program that is already installed have unknown SUID binary. As we see, its name is “**enlightenment**”. After doing some research, we see that Enlightenment is vulnerable and has a CVE number of CVE-2022-37706.

This gave me the root id and finished the challenge